

# Risk Scoring Report

Project: `vulnerable-invoice-service` · Stage 2 (Grype-weighted) · Generated 2026-06-18 · Model: `0.5·CVE + 0.3·exposure + 0.2·criticality`

## Post-remediation backlog (branch `fix/depscan-20260618-065936`)

| # | Coordinate                      | Old ver    | New ver    | Band    | Risk    | Top CVE               | Status        |
|---|---------------------------------|------------|------------|---------|---------|-----------------------|---------------|
| 1 | log4j-core / log4j-api          | 2.14.1     | 2.25.4     | CLEARED | 7.8 → 0 | CVE-2021-44228 (10.0) | fixed in PR   |
| 2 | jackson-databind                | 2.9.8      | 2.18.3     | CLEARED | 7.8 → 0 | CVE-2020-8840 (9.8)   | fixed in PR   |
| 3 | mysql-connector-java            | 8.0.30     | —          | HIGH    | 7.2     | CVE-2023-22102 (8.9)  | MAJOR_REVIEW  |
| 4 | commons-io                      | 2.4        | 2.18.0     | CLEARED | 7.1 → 0 | CVE-2024-47554 (8.7)  | fixed in PR   |
| 5 | commons-lang3                   | 3.4        | 3.18.0     | CLEARED | 5.8 → 0 | CVE-2025-48924 (6.5)  | fixed in PR   |
| 6 | guava                           | 24.1.1-jre | 33.4.0-jre | CLEARED | 5.5 → 0 | CVE-2023-2976 (5.5)   | fixed in PR   |
| 7 | com.fastxml...:jackson-databind | 2.9.8      | removed    | CLEARED | —       | TYPOSQUAT             | removed in PR |

## Component scores (post-fix)

| Dependency           | CVE severity | Exposure | Business criticality | Weighted | Δ                |
|----------------------|--------------|----------|----------------------|----------|------------------|
| log4j-core           | 0            | 8.0      | 2.0                  | 1.6      | -6.2             |
| jackson-databind     | 0            | 8.0      | 2.0                  | 1.6      | -6.2             |
| mysql-connector-java | 8.9          | 8.0      | 2.0                  | 7.2      | 0 (MAJOR_REVIEW) |
| guava                | 0            | 7.0      | 2.0                  | 1.4      | -4.1             |
| commons-io           | 0            | 7.0      | 2.0                  | 1.4      | -5.7             |
| commons-lang3        | 0            | 7.0      | 2.0                  | 1.4      | -4.4             |

## Priority recommendations (remaining)

- P0** — Migrate `mysql:mysql-connector-java:8.0.30` → `com.mysql:mysql-connector-j:9.1.0` (coordinate + major version change; CVE-2023-22102 CVSS 8.9; track as MAJOR\_REVIEW issue).
- P1** — Remove the untrusted HTTP repository `http://insecure-mirror.example.net/maven2` from `<repositories>` (supply-chain, manual fix).

Machine-readable source: `depscan-risk-report.json` . Generated by the *Dependency & Supply-Chain Plugin* — Stage 2 / Stage 3 (post-remediation).